مفردات حوكمة الأمن السيبراني

مقدمة في الأمن السيبراني وحوكمة أمن المعلومات

محاضرة الأسبوع الأول ـــــمدة المحاضرة :ساعة ونصف

إعداد وتقديم :أ.د. ضياء جاسم كاظم

عن هذه المحاضرة

لمحة عامة عن محاضرة اليوم

1

المدة الزمنية

ساعة ونصف موزعة على محورين رئيسيين مع فاصل نقاش

2

المحور الأول

مدخل شامل إلى مفاهيم الأمن السيبراني الأساسية

3

المحور الثاني

مدخل إلى حوكمة أمن المعلومات ودورها في حماية المؤسسات

4

الأسلوب

عرض نظري مدعوم بأمثلة واقعية ونقاش تفاعلي

بنهاية هذه المحاضرة سيكون الطالب قادراً على

1. تعريف الأمن السيبراني وتوضيح أهميته للمؤسسات والأفراد
2. شرح مثلث CIAوالمبادئ الأساسية لأمن المعلومات
3. تصنيف أبرز التهديدات السيبرانية والفاعلين وراءها
4. تعريف حوكمة أمن المعلومات والتمييز بينها وبين الإدارة التنفيذية
5. التعرف على أركان الحوكمة وأصحاب المصلحة الرئيسيين

جدول أعمال الساعة والنصف

1

مدخل إلى الأمن السيبراني

التعريفات، الأهمية، التطور التاريخي، مثلث CIA — 25 دقيقة

2

التهديدات والفاعلون

أنواع الهجمات، الجهات المهاجمة، أمثلة واقعية — 20 دقيقة

3

استراحة ونقاش قصير

أسئلة وتفاعل مع الطلاب — 5 دقائق

4

مدخل إلى الحوكمة

تعريف الحوكمة، أركانها، أصحاب المصلحة — 25 دقيقة

5

الأطر والتشريعات

لمحة تمهيدية عن الأطر القادمة والبيئة التنظيمية — 10 دقائق

6

الملخص والمصطلحات

مراجعة عامة، أسئلة نقاش، تحضير للأسبوع القادم — 5 دقائق

١

مدخل إلى الأمن السيبراني

المفاهيم الأساسية والأهمية والتطور التاريخي

ما هو الأمن السيبراني؟

1

التعريف العام

مجموعة الممارسات والتقنيات والسياسات التي تهدف إلى حماية الأنظمة والشبكات والبيانات من الوصول غير المصرح به أو الهجمات أو الأضرار

2

النطاق

يشمل حماية الأجهزة، البرمجيات، الشبكات، البيانات، وحتى سلوك المستخدمين أنفسهم

3

الهدف النهائي

ضمان استمرارية الأعمال، حماية الخصوصية، والحفاظ على ثقة أصحاب المصلحة

الأمن السيبراني في صميم استمرارية الأعمال

24/7

المؤسسات تتعرض لمحاولات اختراق واستطلاع مستمرة على مدار الساعة

↑٪

ارتفاع مستمر في تكلفة الحوادث السيبرانية وتأثيرها على السمعة

بيانات

تحوّل البيانات إلى أصل استراتيجي يستوجب حماية مماثلة للأصول المالية

الأرقام الدقيقة تختلف حسب القطاع والتقارير السنوية الصادرة عن جهات عالمية متخصصة.

تطور الأمن السيبراني عبر الزمن

١٩٧٠

أولى تجارب الفيروسات وبرمجيات الاختبار الذاتي

١٩٨٨

دودة موريس وأول جرس إنذار عالمي

٢٠٠٠

انتشار الفيروسات عبر البريد الإلكتروني

٢٠١٠

ظهور التهديدات المتقدمة المستمرة APT

٢٠٢٠+

برمجيات الفدية والذكاء الاصطناعي في الهجمات

مثلث CIA لأمن المعلومات

س

السرية Confidentiality

ضمان عدم اطلاع غير المصرح لهم على المعلومات الحساسة

ص

السلامة Integrity

ضمان دقة البيانات واكتمالها وعدم التلاعب بها دون تصريح

ت

التوافر Availability

ضمان وصول المستخدمين المخولين للمعلومات والأنظمة عند الحاجة

مبادئ إضافية لأمن المعلومات

1

المصادقة Authentication

التحقق من هوية المستخدم أو الجهة قبل منح الوصول

2

التفويض Authorization

تحديد الصلاحيات المسموح بها لكل مستخدم بعد التحقق من هويته

3

عدم الإنكار Non-repudiation

ضمان عدم قدرة أي طرف على إنكار قيامه بعملية معينة

4

المساءلة Accountability

ربط كل نشاط بجهة أو شخص مسؤول عنه، ومهمة أساسية تربط الأمن بالحوكمة

أبرز أنواع التهديدات الشائعة

1

البرمجيات الخبيثة

فيروسات وديدان وأحصنة طروادة تُصيب الأنظمة وتُلحق الضرر بها

2

برمجيات الفدية

تشفير بيانات الضحية والمطالبة بفدية مالية لاستعادتها

3

التصيد الاحتيالي

رسائل مزيفة تخدع المستخدم للكشف عن بيانات حساسة

4

هجمات حجب الخدمة

إغراق الأنظمة بالطلبات لتعطيلها عن العمل الطبيعي

5

الهندسة الاجتماعية

استغلال الثقة والسلوك البشري بدلاً من الثغرات التقنية

6

التهديدات الداخلية

موظفون أو أطراف موثوقة يسيئون استخدام صلاحياتهم

من يقف خلف الهجمات السيبرانية؟

1

قراصنة أفراد

أفراد يسعون لتحقيق مكاسب مادية أو إثبات القدرة التقنية

2

جماعات إجرامية منظمة

شبكات منظمة تستهدف المؤسسات بدافع الربح المالي

3

جهات مدعومة من دول

هجمات موجهة لأغراض استخباراتية أو سياسية أو عسكرية

4

الناشطون السيبرانيون

هجمات بدوافع أيديولوجية أو سياسية أو اجتماعية

أبرز المنافذ التي يستغلها المهاجمون

1. البريد الإلكتروني والمرفقات أو الروابط الخبيثة
2. الثغرات غير المحدّثة في الأنظمة والتطبيقات
3. كلمات المرور الضعيفة أو المسرّبة
4. الأجهزة المحمولة وشبكات الواي فاي غير الآمنة
5. الأطراف الثالثة والموردون المرتبطون بالمؤسسة

لماذا تحدث هذه الاختراقات غالباً؟

1

ضعف الوعي البشري

غالبية الحوادث تبدأ بخطأ بشري أو نقص في التدريب والتوعية

2

غياب التحديثات

تأخر تطبيق التحديثات الأمنية يترك ثغرات معروفة مفتوحة

3

ضعف الحوكمة

غياب سياسات واضحة وأدوار محددة يُضعف الاستجابة للحوادث

المجالات الرئيسية للأمن السيبراني

1

أمن الشبكات

حماية البنية التحتية للشبكات من الاختراق والتنصت

2

أمن التطبيقات

تأمين البرمجيات من مرحلة التصميم حتى التشغيل

3

أمن السحابة

حماية البيانات والخدمات المستضافة على بيئات سحابية

4

أمن البيانات

حماية سرية وسلامة البيانات أثناء التخزين والنقل

5

أمن نقاط النهاية

تأمين الأجهزة الطرفية كالحواسيب والهواتف

6

الاستجابة للحوادث

الكشف عن الحوادث الأمنية والتعامل معها بسرعة وفعالية